

Controls and compliance checklist

The checklist and recommendations below refers to the information provided in the [scope, goals, and risk assessment report](#).

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Does Botium Toys currently adhere to this compliance best practice?

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
------------	-----------	----------------------

- | | | |
|-------------------------------------|-------------------------------------|--|
| ☐ | ☒ | User access policies are established. |
| ☐ | ☒ | Sensitive data (PII/SPII) is confidential/private. |
| ☒ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☐ | ☒ | Data is available to individuals authorized to access it. |
-

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

Recommendations: There are several security leaks which are generating extremely high risk to the company and need to be fixed as soon as possible.

-Asset Management (Priority 1): The first step, based on NIST CSF is to identify data and make sure it's properly classified and inventoried.

-Access Control (Priority 2): Second step is to look at the Least Privilege concept and safely introduce it to your policies as it's giving everybody access to everything.

-Data Protection & Compliance (Priority 3): The third step is upgrading the Password (Authentication) and Encryption (Confidentiality) field, the current state of data security is critical, with a huge warning to the credit card data field (that is violating the PCI DSS patterns), which is completely open and any incident could cause a huge damage to the clients PII/SPII and also to the company reputation as it absence of control also violates the GDPR.

-Resilience (Priority 4): Next steps cover a better Intrusion detection system (IDS) and finally adding a Backup plan for data recovery in case of a possible attack. That ensures business continuity.